

Cloud Shared Responsibility and Compliance Report

Name: Solomon Mwaura

Date: March 15, 2026

1. Shared Responsibility Analysis

Objective: Identify and document the responsibilities of the cloud provider and the customer in securing the cloud environment.

Component	Cloud Provider Responsibility	Healthcare Organization Responsibility
Data Encryption	Provide hardware-level encryption and underlying cryptographic services.	Encrypt on-premises data; encrypt cloud backups; centralize key management.
Access Control	Secure the physical identity infrastructure and provide IAM framework tools.	Define user lifecycles; conduct periodic access reviews; enforce MFA across hybrid sites.
Monitoring and Response	Monitor the availability and security of the cloud platform fabric.	Integrate hybrid logs into a centralized SIEM; develop hybrid-specific Incident Response plans.
Network Security	Protect physical cabling, routers, and global network edge from DDoS.	Patch/update on-premises firewalls; secure administrative interfaces (RDP/SSH) for VMs.

Backup and Recovery	Provide durable storage and high-availability infrastructure.	Encrypt backups; document and test Disaster Recovery (DR) for the integrated hybrid flow.
----------------------------	---	---

2. Cloud Security Architecture Evaluation

Objective: Assess the current cloud environment against industry best practices and identify gaps.

Best Practice	Implemented	Notes (Gap/Importance)
Data encryption (Rest/Transit)	Partially	Cloud data is encrypted, but backups are not . This is a major gap; unencrypted backups are a primary target for ransomware.
Centralized key management	No	Keys are managed in disparate systems. This leads to administrative overhead and high risk of key loss or unauthorized access.
Multi-factor authentication	No	Not mentioned as active. MFA is the single most effective control against the "failed login" attempts noted in the logs.
Principle of least privilege	No	Roles are manually managed with no lifecycle or reviews. This leads to "privilege creep" and dormant accounts.
Automated monitoring/alerting	Partially	Built-in tools exist, but there is no centralized visibility across the hybrid environment. Detection is siloed.

Network segmentation	Partially	IP limiting is used for VMs, but outdated on-premises firewalls cannot perform Deep Packet Inspection (DPI).
Regular vulnerability assessments	No	No evidence of a scanning schedule. Outdated firewalls suggest a lack of proactive vulnerability management.
Tested disaster recovery plans	No	Current plans do not account for hybrid risks, and there is no evidence that the cloud backups have been tested.

3. HIPAA Compliance Comparison

Objective: Compare cloud security best practices to HIPAA compliance requirements.

HIPAA Requirement	Current Practice	Gap or Improvement Needed
Administrative Safeguards	Manual user role management.	GAP: Fails 45 CFR §164.308(a)(4). Need formal procedures for account deactivation and periodic access reviews.
Physical Safeguards	Outsourced to cloud provider.	NO GAP: Cloud provider manages data center security (SOC 2 Type II compliance).
Technical Safeguards	Data encrypted in cloud.	GAP: Fails 45 CFR §164.312(a)(2)(iv). Backups must be encrypted; encryption keys require centralized integrity control.

4. Recommendations for Improvement

Summary of Recommendations:

1. **Centralize Key Management (AWS KMS / Azure Key Vault):** Transition all on-premises and cloud keys to a single management platform. This ensures that even if backups are stolen, the data remains unreadable without centrally controlled keys.
2. **Encrypt All Backups:** Immediately enable encryption for cloud-based backups. Under HIPAA, unencrypted PHI in backups is considered a "breach" if accessed by unauthorized parties, regardless of where it is stored.
3. **Implement Hybrid SIEM (Centralized Logging):** Integrate on-premises firewall logs and cloud provider logs into a single dashboard. This allows the security team to correlate a failed login on-premises with suspicious activity in the cloud.
4. **Enforce MFA and Access Lifecycles:** Implement Multi-Factor Authentication for all administrative access. Automate account deactivation linked to the HR system to ensure the "Principle of Least Privilege" is maintained.
5. **Upgrade On-Premises Firewalls:** Replace legacy hardware with Next-Generation Firewalls (NGFW) that support Deep Packet Inspection and can communicate with cloud-based security groups for a unified defense.